Group 18: QAKBOT Infection

Darren N, Christopher D, Tori C, Jayden P, Rohith A, Elshaday T

Sample Dataset

2020s Qakbot (Qbot) Infection with Cobalt Strike

Link to dataset:

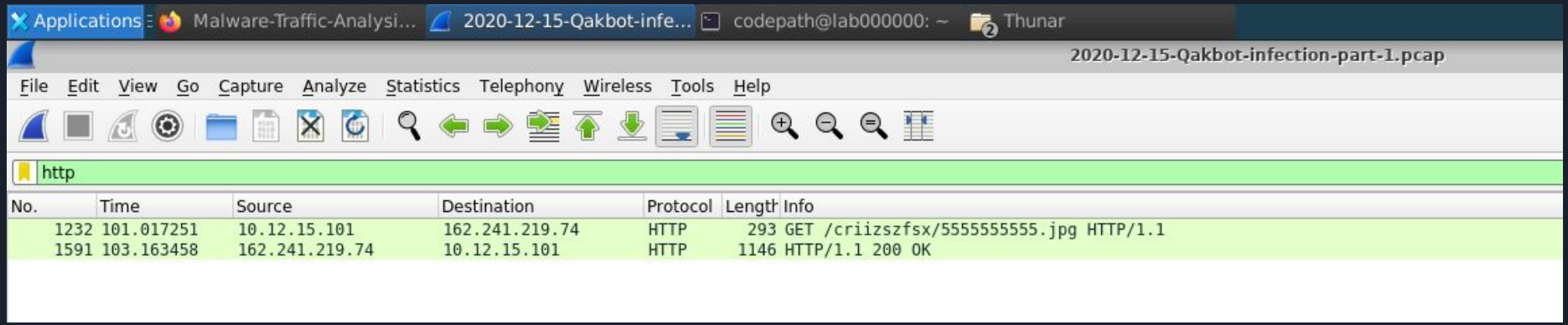
https://www.malware-traffic-analysis.net/2020/12/15/index.html

Monitoring Sources

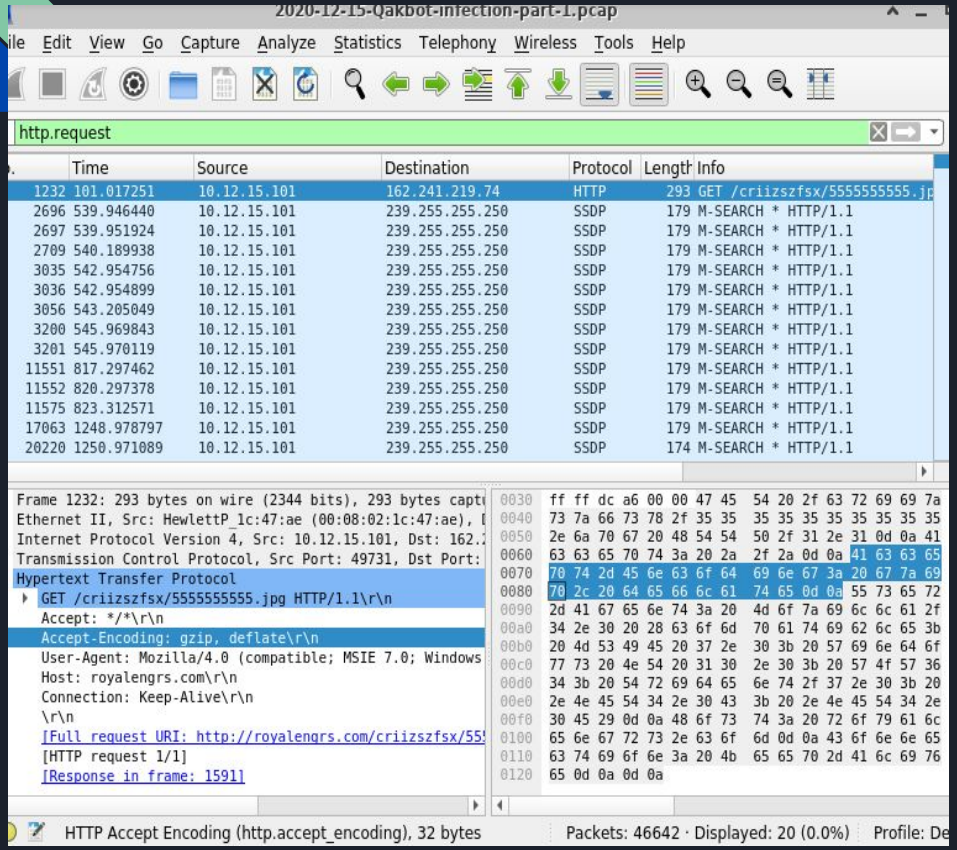
Two Qakbot infection pcap files
Malware .eml file
Qakbot Cobalt Strike IOC .txt file
Malware .jpg file
.dll file
Excel file

IOC Sites Found in the files

1. Initial infected machine downloading jpg file from attacker
2. 162.241.219.74 (royalengrs.com, initial payload)
3. 78.101.199.138:995 (Qakbot C2)
4. 172.241.27.244 (matesmapizza.com/travmeetlett.com, Cobalt Strike C2)



Beginning of Malware Attack



The Get Request is an indicator of the moment that the host of the affected computer downloaded the malware.

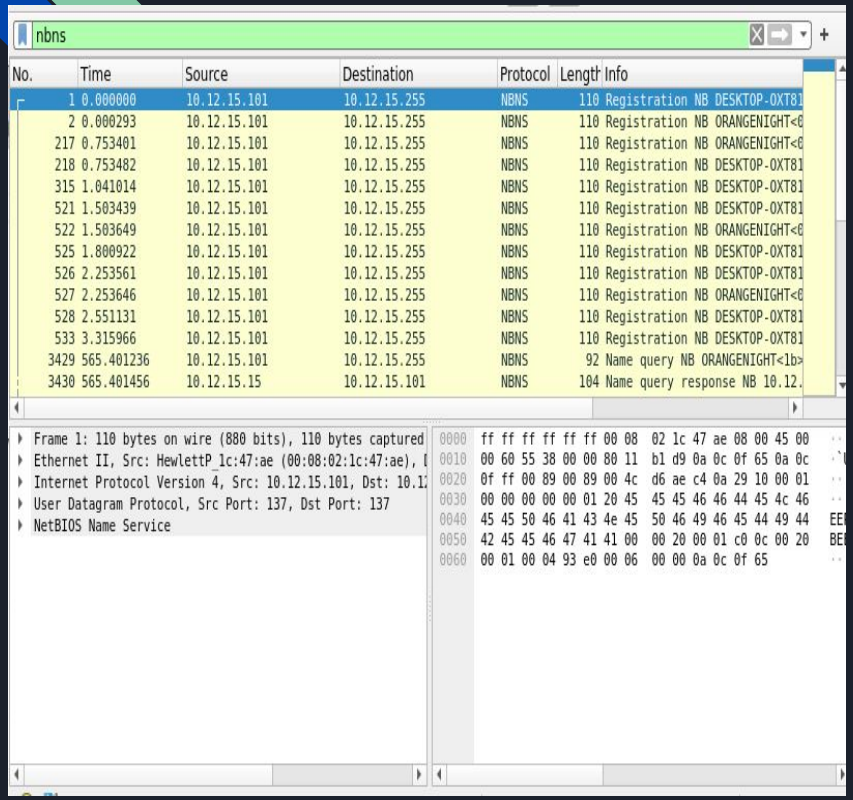
Executive Summary

An employee's computer was infected with malware disguised as a regular file. Once infected, the machine secretly contacted an external attacker every 5 minutes,which could have led to the malicious data being share throughout the network. Our team detected an traced this activity through network monitoring where we identified and container it without tipping off the attacker.

- HTTP/ Get Request
- Delivered as the JPG File



Hacked Computers



Active Directory: ORANGENIGHT

Desktop : OXT814S

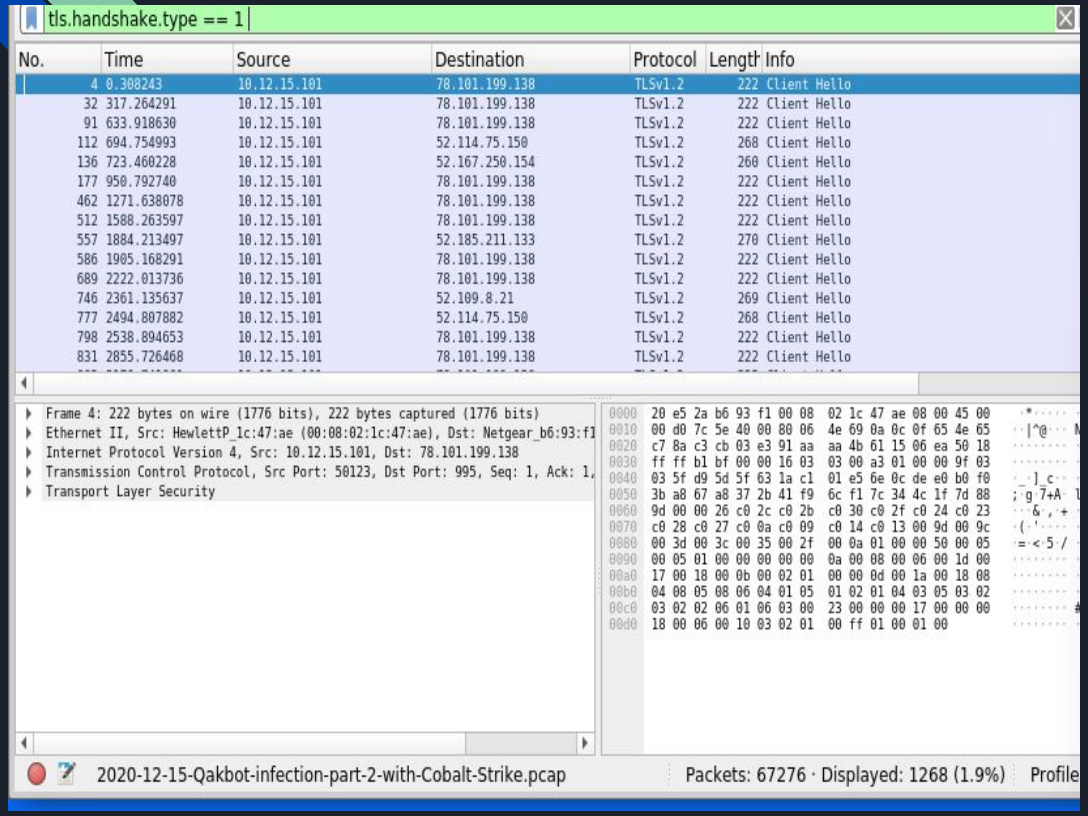
Domain Controller: 10.12.15.15

Victim IP address: 10.12.15.101



Used NetBIOS Name Service like a nosy aunt snitching on the infected device owner. Based on the data it seems to be a desktop in a company probably just minding its business drinking coffee when an unexpected malware showed up. Allowing me to pull an Uno Reverse Card quietly figuring out which system was compromised while the attacker had zero idea.

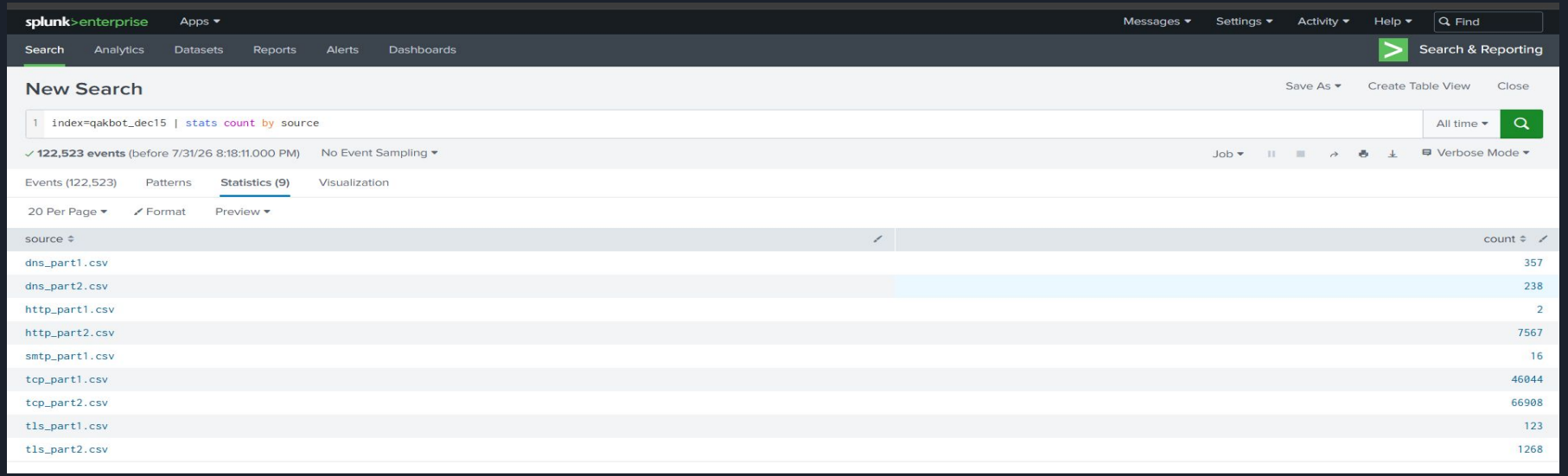
Five minute Beacon intervals



- Filtered the transport layer to find the first packet the computer sent to the attacker.

Splunk-Based Timeline Reconstruction

- Ingested HTTP, DNS, TLS, SMTP, and TCP traffic into Splunk
- Built custom sourcetype to correctly parse original 2020 timestamps — critical for accurate timeline
- Resolved data ingestion challenges (timestamp parsing, field collisions) to ensure reliable analysis



Reconstructed Infection Timeline

- Initial payload delivered 21:33:47 (disguised .jpg download from 162.241.219.74)
- Qakbot C2 beacon established 21:41:28, sustained ~8 hours (78.101.199.138, port 995)
- Cobalt Strike escalation began 04:49:01 (~7hr 15min dwell time) via 172.241.27.244
- Confirmed beacon behavior through repeated connection analysis (6,241 events to single C2 IP)

```
index=qakbot_dec15 (Destination="162.241.219.74" OR Destination="78.101.199.138" OR Destination="172.241.27.244")
| eval stage=case(Destination="162.241.219.74","1-Initial Payload", Destination="78.101.199.138","2-Qakbot C2", Destination="172.241.27.244","3-Cobalt Strike")
| stats count earliest(_time) as first_seen latest(_time) as last_seen by stage
| convert ctime(first_seen) ctime(last_seen)
| sort stage
```

All time

✓ **35,048 events** (before 7/31/26 9:23:35.000 PM) No Event Sampling

Job Verbose Mode

Events (35,048) Patterns **Statistics (3)** Visualization

100 Per Page Format Preview

stage	count	first_seen	last_seen
1-Initial Payload	177	12/15/2020 21:33:47.310615	12/15/2020 21:35:37.156361
2-Qakbot C2	6241	12/15/2020 21:41:28.449333	12/16/2020 05:22:13.385624
3-Cobalt Strike	28630	12/16/2020 04:49:01.195823	12/16/2020 06:39:47.509912

Consolidated Analysis & Severity Assessment

Qakbot-CobaltStrike Timeline

Edit | Export | ...

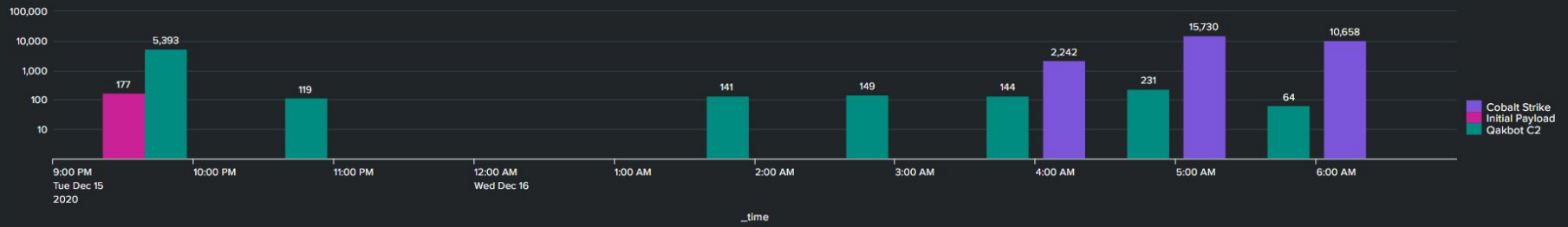
HTTP Payload Delivery

10.12.15.101

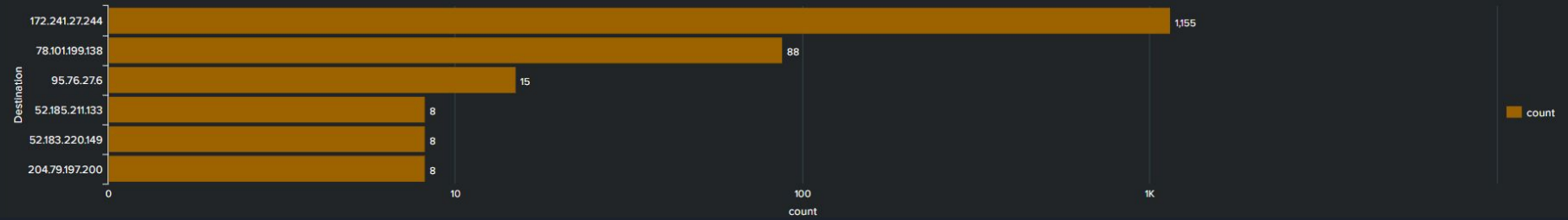
Infection Kill Chain Overview

stage	count	first_seen	last_seen
1-Initial Payload	177	12/15/2020 21:33:47.310615	12/15/2020 21:35:37.156361
2-Qakbot C2	6241	12/15/2020 21:41:28.449333	12/16/2020 05:22:13.385624
3-Cobalt Strike	28630	12/16/2020 04:49:01.195823	12/16/2020 06:39:47.509912

Attack Volume Over Time

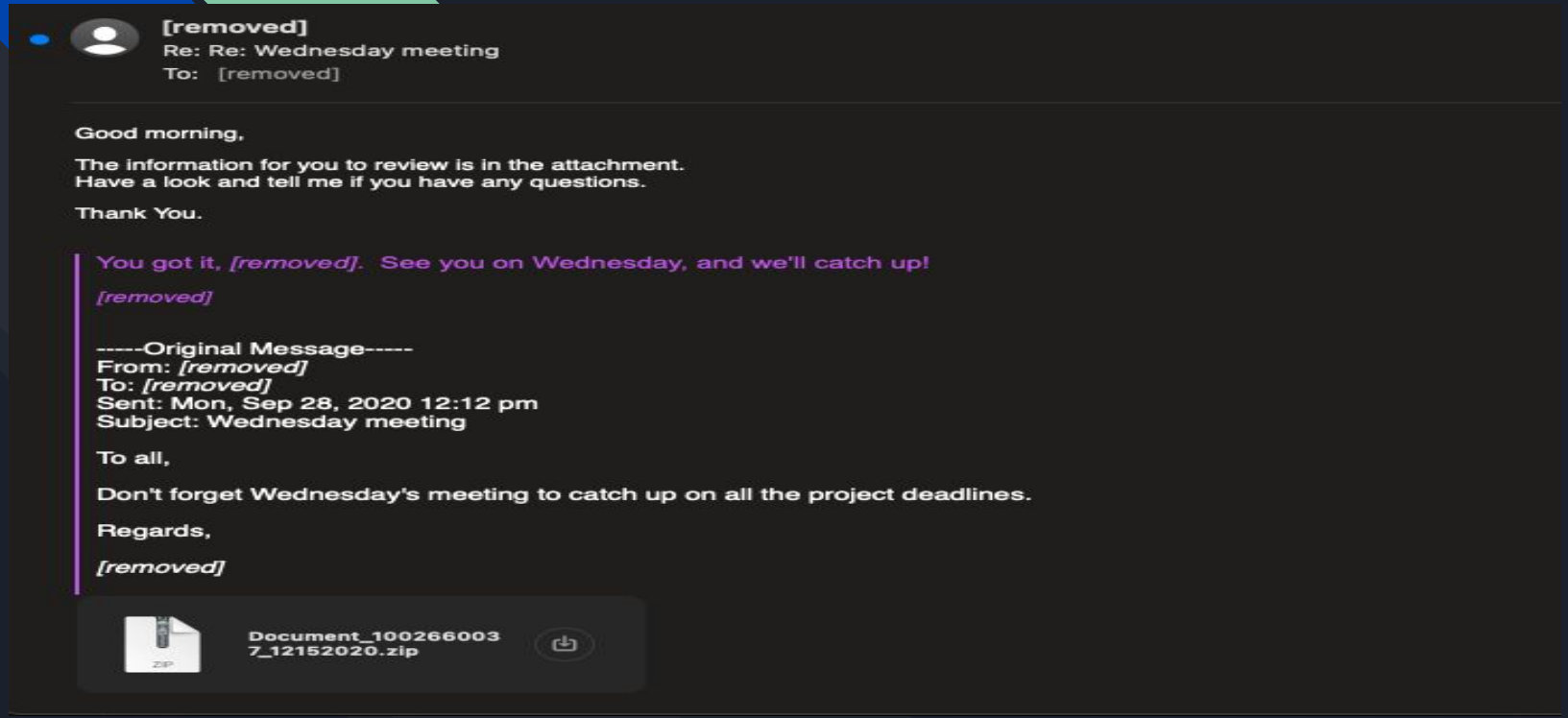


Suspicious Beacon Confirmation



Initial Compromised Host

The phishing email serves as the initial incident entry point, containing a malicious attachment that triggered the infection chain. This artifact provides evidence of social engineering tactic used to initiate the compromise.

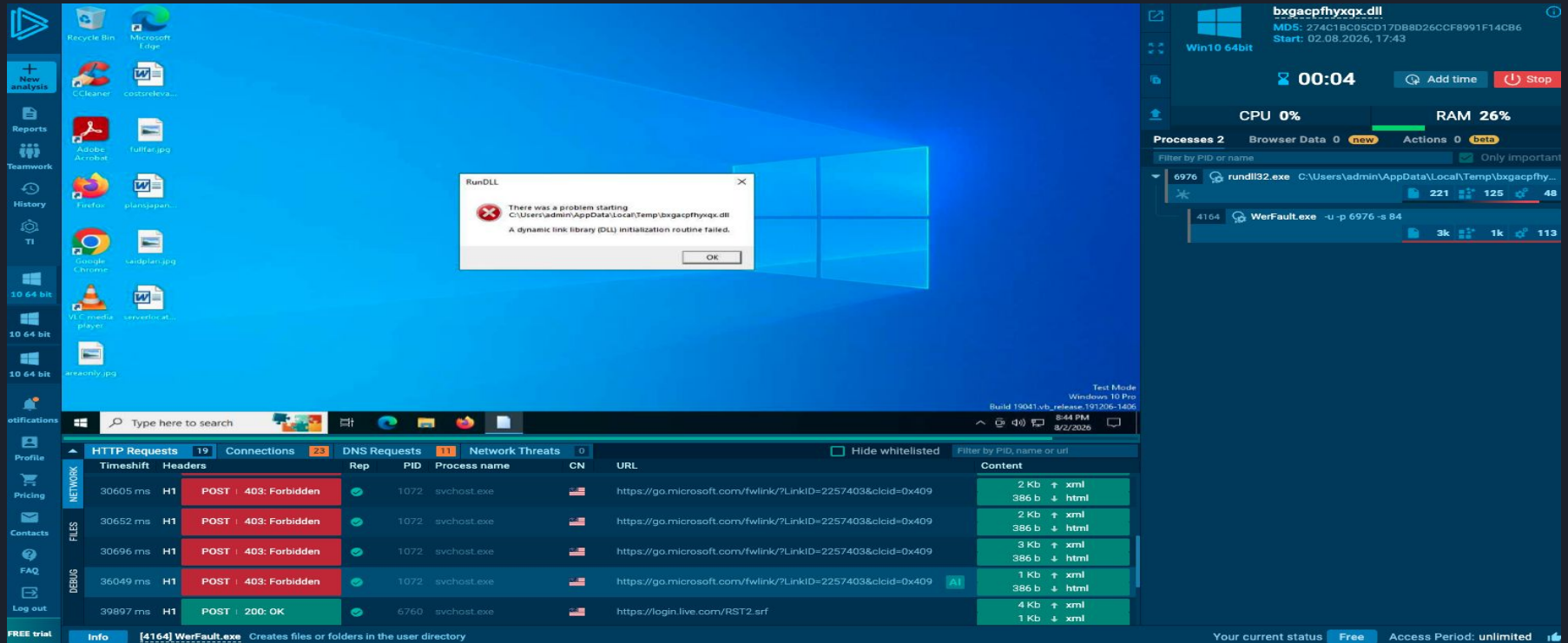


Outbound Connection Analysis (Zeek)

- Continuous outbound traffic observed from **10.12.15.101 (infected host)**
- High-frequency connections to **172.241.27.244** over ports **80, 443, and 8888**
- Traffic includes both **HTTP and SSL**, indicating attempts to blend with normal web activity
- Repeated, short-duration connections show clear **beaconing behavior**
- Large number of connections confirms **active Cobalt Strike C2 communication**

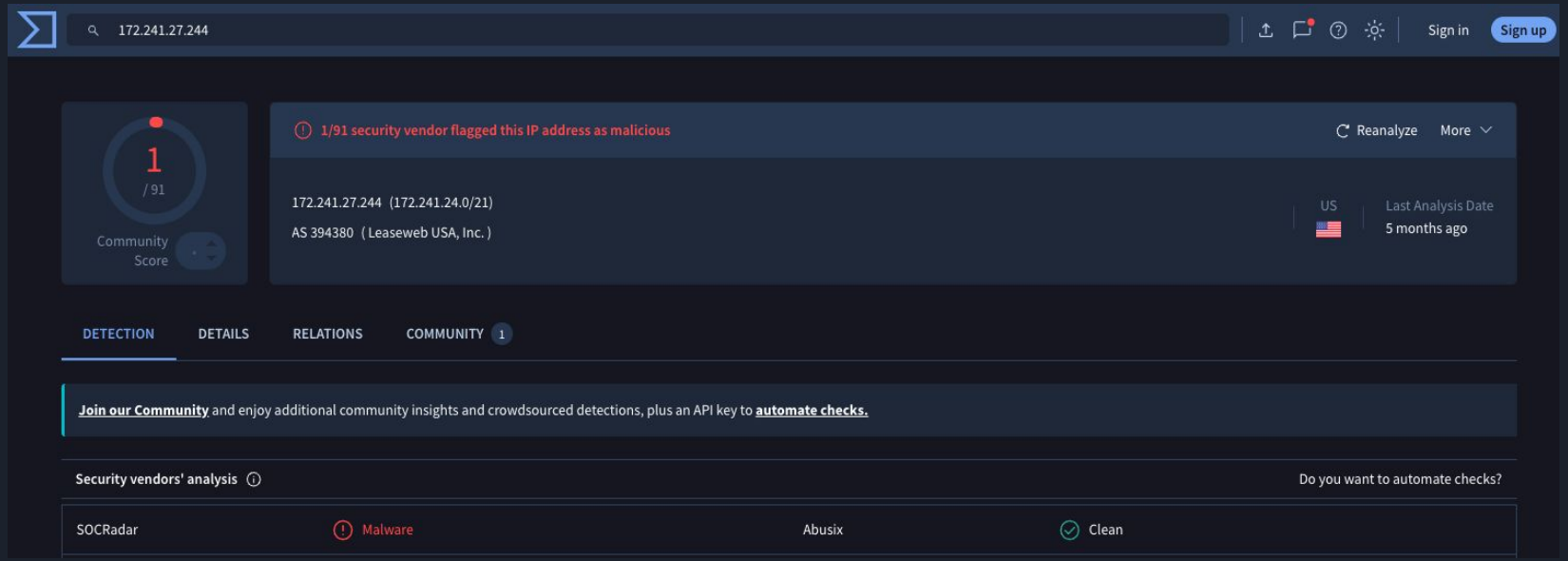
Dynamic Malware Analysis (ANY.RUN)

Executed suspicious file in sandbox environment, observed process spawning and network connections, Identified outbound communication to C2 infrastructure, was able to confirm malicious behavior consistent with QakBot



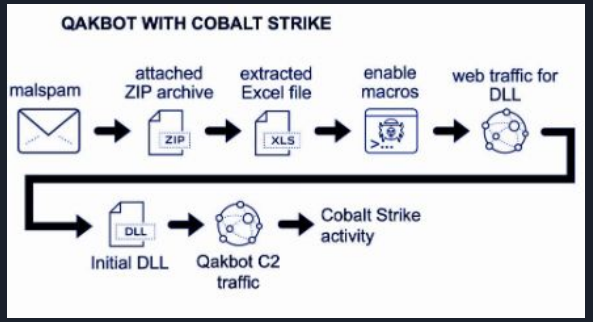
Threat Intelligence Validation (VirusTotal)

- Low signature detection despite confirmed C2 activity
- Despite this, Zeek analysis confirms: High-frequency beaconing behavior and over 6000 outbound connections to a single host which indicates active command and control /c2 communication.



Full Qakbot execution timeline

- Phishing email disguised as workplace message
- User downloads & opens malicious ZIP attachment
- Malware (QakBot) executes on victim machine
- Initial outbound communication to QakBot C2 (78.101.199.138)
- Attacker gains foothold and remains undetected (dwell time)
- Cobalt Strike deployed for post-exploitation. The machine is now actively being controlled by the attacker.
- Repeated beaconing to external C2 server begins
- Internal communication with domain controller observed



Impact & Triage

Key Takeaway

One phishing email led to full Domain Controller exposure in under 8 hours.

Cobalt Strike is dangerous because it blends in with legit network traffic, controls infected machines, allows data exfiltration, laterally spread across network, and deliver additional malware components like ransomware

How to Defend Against It

- **Monitor constantly:** catch beaconing and unusual traffic early
- **Have a response plan:** act fast when something is found
- **Train employees:** most attacks start with one click
- **Use threat intel:** block known C2 servers before they connect

Phase 1
Fast Detection

+

Phase 2
Fast Response

=

The Difference Between An
Incident & Breach

Recommended Remediation

What should be done:

1. Isolate **infected** host
2. **Block** all C2 IPs
3. Disable **compromised** accounts
4. Rebuilt host, reset **credentials**
5. **Update** training & email filters



Used to ensure an incident like this never happens again



Thank You!

Threat Intelligence & Incident Response

CYB 102 — Presentation End